Access control: summary

BienSync · branch `superadmin-ui-2` · 31 October 2026

Before

- Only Staff were checked; Admins had full access.
- Only Appointments was enforced.
- Module names were free text (typos blocked access).
- Admins could create Staff only, never Admins.
- No screen to manage access.

Now

- Admins and Staff both have a grid: View / Create / Edit / Delete per module.
- Only the SuperAdmin skips the checks.
- Fixed module list; View is automatic.
- Admins can create Staff and Admins, if allowed.
- Access pages on the platform and a new Team page.

The rules

- **No passing on more than you have:** an Admin can only grant access they hold.
- **Removing access goes down the chain:** it's also removed from everyone that user created.
- **Starting access:** new Admin = full (made by SuperAdmin) or the creator's access (made by an Admin); new Staff = nothing.
- Admins can't change their own access or anyone's role, and only manage their own clinic.

Roles

Role	Can do
SuperAdmin	Everything. Sets anyone's access from Users → Access.
Admin	What their grid allows. The **Staff** and **Admins** modules control managing people (see, add, edit + access, remove). Works from the Team page.
Staff	What their grid allows. Can never manage people.

Checked by the API today: **Appointments, Staff, Admins**. The other modules aren't enforced yet.

Database (local only)

- New column `User.created_by_id` (who created whom), added with `prisma db update`.
- Existing Admins given full access by `src/prisma/backfill-admin-access.ts`. Run it once on any other database.
- Fixed a Prisma bug: `.where().delete()` / `.update()` only changed one row; 18 calls now use `deleteAndCount()` / `updateAndCount()`.

Not done yet

- Removing access doesn't reach Staff created before this change.
- Patients, Doctors, Messages, Reviews and Finances still need API checks.
- Not tested in the browser, and not committed.